

HAL

SECURITY, PRIVACY, AND TRUST MANUAL

Book VI • Version 1.0 • Final

Continuous protection. Bounded authority. Accountable trust.

HAL Book VI — Security, Privacy, and Trust Manual

Version: 1.0

Status: Final

Effective date: 2026-07-27

Control count: 112

Authority statement

Book I is supreme. Book II is the authoritative architecture. Book III governs engineering practice. Book IV defines component responsibilities. Book X governs semantics. Book VI governs the ongoing security, privacy, and trust program. Book VI does not create Authority, machine contracts, component responsibilities, or certification authority.

Revision history

Version	Date	Status	Change
---	---	---	---
1.0	2026-07-27	Final	First complete controlled edition.

Table of contents

- 1. Authority, Scope, and Security-Privacy-Trust Program Governance
- 2. Identity Assurance and Access Governance
- 3. Privileged Access, Break-Glass, Credentials, and Service Identities
- 4. Cryptography, Secrets, Keys, and Certificates
- 5. Platform, Network, Workload, Build, and Supply-Chain Security
- 6. Vulnerability, Exposure, and Patch Management
- 7. Privacy Governance, Classification, Purpose, and Data Lifecycle
- 8. Sensitive Processing, Inference Risk, Human Dignity, and Privacy Incidents
- 9. Trust Domains, Constitutional Firewall, and Cross-Domain Exchange

10. Treaty Lifecycle and Third-Party Trust Governance
11. Detection, Telemetry, and Security Operations
12. Incident Response, Investigation, Evidence Preservation, and Notification
13. Compromise Recovery, Offensive Assurance, Audit, and Security Certification Inputs
14. Metrics, Continuous Improvement, Reconciliation, and Program Conformance

Program conformance model

Every applicable control **MUST** be implemented, evidenced, verified, monitored, and assigned. Critical control failure constrains affected operation and triggers incident or assurance review. Exceptions cannot waive constitutional invariants or create Authority. The control objective field explicitly distinguishes protecting HAL from preventing HAL from exceeding its Authority.

Chapter 1 — Authority, Scope, and Security-Privacy-Trust Program Governance

1. Document control

- Identifier: HAL-BVI-01
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Establish the living program, authority hierarchy, accountable roles, control ownership, risk treatment, exceptions, and the non-transfer of constitutional authority.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Articles I-XIV; Decisions 1, 5, 26, 27, 47, 48, 58
- Book II: Chapters 1, 3-5, 35
- Book III: Chapters 1, 5, 8-9
- Book IV: CMP-01, CMP-03, CMP-17-21, CMP-24
- Book X: Chapters 1, 3-4, 7-8, 10
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Owner, Security and Trust Executive, Control Owner, Risk Steward, Independent Assessor, Evidence Custodian.

6. Normative controls

VI-GOV-01-001 — Apply the canon hierarchy

Every program decision **MUST** preserve Book I, implement Book II, follow Book III, respect Book IV ownership, and use Book X semantics; conflict **MUST** halt the affected decision and be recorded.

- Applicability: all program decisions
- Responsible role: Security and Trust Executive
- Enforcement: source-version gate and conflict workflow
- Required evidence: source manifest and decision record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-GOV-01-002 — Separate protection from restraint

Every risk assessment and control design **MUST** state whether it protects HAL, prevents HAL from exceeding Authority, or does both; neither objective **MAY** be omitted when applicable.

- Applicability: all controls and risks
- Responsible role: Control Owner
- Enforcement: control-schema validation
- Required evidence: control record with protection objective
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-GOV-01-003 — Assign control accountability

Each active control **MUST** have one accountable Control Owner, identified operators, an assessor, evidence, test frequency, failure response, and succession coverage.

- Applicability: all controls
- Responsible role: Security and Trust Executive
- Enforcement: catalog completeness gate
- Required evidence: approved control assignment
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-GOV-01-004 — Classify risk by consequence

Risks **MUST** be classified using the highest material consequence across authority, constitutional invariant, privacy, trust boundary, compromise, continuity, safety, irreversibility, and blast radius.

- Applicability: all risks
- Responsible role: Risk Steward
- Enforcement: risk-register validation and review
- Required evidence: risk assessment
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-GOV-01-005 — Maintain separation of duties

No person or service **MAY** solely request, approve, execute, and attest a protected security, privacy, trust, key, Treaty, or break-glass change.

- Applicability: protected changes
- Responsible role: Control Owner
- Enforcement: role-conflict policy
- Required evidence: approval and execution evidence
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-GOV-01-006 — Operate a control lifecycle

Controls **MUST** be proposed, reviewed, approved, implemented, tested, monitored, remediated, and retired through versioned records with preserved history.

- Applicability: all controls
- Responsible role: Control Owner
- Enforcement: control-state machine
- Required evidence: control lifecycle record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-GOV-01-007 — Time-bound all exceptions

An exception **MUST** identify control, scope, rationale, risk, compensating controls, approver, evidence, effective date, review date, expiry, and revocation triggers; silent or permanent exceptions are prohibited.

- Applicability: all exceptions
- Responsible role: Risk Steward
- Enforcement: exception registry and expiry enforcement
- Required evidence: signed exception record
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-GOV-01-008 — Forbid program-created authority

Security status, trust, identity, credentials, certificates, risk acceptance, or control compliance **MUST NOT** create Permission, Authority, Owner approval, capability-class approval, or Treaty scope.

- Applicability: all program actions
- Responsible role: Security and Trust Executive
- Enforcement: negative authority-path tests
- Required evidence: authority non-creation attestation
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Articles I-XIV; Decisions 1, 5, 26, 27, 47, 48, 58
- Book II: Chapters 1, 3-5, 35
- Book III: Chapters 1, 5, 8-9
- Book IV: CMP-01, CMP-03, CMP-17-21, CMP-24
- Book X: Chapters 1, 3-4, 7-8, 10

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 2 — Identity Assurance and Access Governance

1. Document control

- Identifier: HAL-BVI-02
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern identity proofing, authentication assurance, authorization dependence, access review, lifecycle events, and identity quarantine.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 6, 27, 47-48
- Book II: Chapters 4-5, 23, 33
- Book III: Chapter 5
- Book IV: CMP-02, CMP-03, CMP-17, CMP-25
- Book X: Chapters 3-4, 8
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Identity Service Owner, Authority Service Owner, Access Administrator, Resource Owner, Security Operations, Independent Assessor.

6. Normative controls

VI-IAM-02-001 — Bind access to immutable identity

Every access decision **MUST** bind an authenticated immutable principal identity; names, locations, devices, network zones, or roles alone **MUST NOT** establish identity.

- Applicability: all access
- Responsible role: Identity Service Owner
- Enforcement: identity-context validation
- Required evidence: authentication record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-IAM-02-002 — Independently authorize every action

Successful authentication **MUST NOT** imply authorization; each protected operation **MUST** obtain a current Authority decision for the exact action, target, purpose, constraints, and time.

- Applicability: protected operations
- Responsible role: Authority Service Owner
- Enforcement: policy enforcement point
- Required evidence: authorization decision evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-IAM-02-003 — Use risk-appropriate authentication

Authentication strength, freshness, liveness, device evidence, and step-up requirements **MUST** be proportionate to the protected consequence and environmental risk.

- Applicability: all sessions
- Responsible role: Identity Service Owner
- Enforcement: adaptive authentication policy
- Required evidence: authentication assurance record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-IAM-02-004 — Review access continuously

Privileged, cross-domain, sensitive-data, and protected-state access **MUST** be reviewed on grant, material change, periodic cadence, incident, role change, and termination.

- Applicability: sensitive access
- Responsible role: Resource Owner
- Enforcement: access review workflow
- Required evidence: access review and disposition
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-IAM-02-005 — Revoke promptly

Termination, compromise, expired delegation, quarantine, loss of need, or material risk increase **MUST** revoke or constrain affected sessions, tokens, permissions, and derived access without waiting for routine review.

- Applicability: access lifecycle events
- Responsible role: Access Administrator
- Enforcement: revocation automation
- Required evidence: revocation receipts
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-IAM-02-006 — Quarantine without identity erasure

Identity quarantine **MUST** restrict new work and credentials, preserve forensic evidence, maintain historical attribution, and require independent release; an identity **MUST NOT** self-release.

- Applicability: suspect identities
- Responsible role: Security Operations
- Enforcement: quarantine state machine
- Required evidence: quarantine and release records
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-IAM-02-007 — Prevent shared identities

Human operators **MUST NOT** share identities; service identities **MUST** be uniquely attributable to one workload identity and accountable owner.

- Applicability: all identities
- Responsible role: Identity Service Owner
- Enforcement: identity inventory scan
- Required evidence: identity registry
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-IAM-02-008 — Minimize access

Permissions **MUST** be purpose-bound, least-privileged, scoped to resources and operations, and expire at the shortest practicable interval consistent with safe operation.

- Applicability: all grants
- Responsible role: Resource Owner
- Enforcement: policy analysis and expiry
- Required evidence: grant record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 6, 27, 47-48
- Book II: Chapters 4-5, 23, 33
- Book III: Chapter 5
- Book IV: CMP-02, CMP-03, CMP-17, CMP-25
- Book X: Chapters 3-4, 8

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 3 — Privileged Access, Break-Glass, Credentials, and Service Identities

1. Document control

- Identifier: HAL-BVI-03
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Control privileged and emergency access, credential issuance and lifecycle, non-human identity, and recovery from privileged compromise.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 27, 38-40, 48
- Book II: Chapters 3-5, 23, 28, 33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-01-03, CMP-25-26
- Book X: Chapters 3-4, 8-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Privileged Access Owner, Incident Commander, Credential Custodian, Service Owner, Security Operations, Independent Reviewer.

6. Normative controls

VI-PAM-03-001 — Broker privileged access

Privileged access **MUST** use an approved broker or equivalent controlled path with strong authentication, current authorization, session bounds, command or action evidence, and automatic expiry.

- Applicability: privileged access
- Responsible role: Privileged Access Owner
- Enforcement: privileged access gateway
- Required evidence: session evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PAM-03-002 — Use just-in-time elevation

Standing privilege **SHOULD NOT** exist; elevation **MUST** be just-in-time, purpose-specific, time-limited, approved at the appropriate risk level, and removed automatically.

- Applicability: privileged roles
- Responsible role: Privileged Access Owner
- Enforcement: elevation workflow
- Required evidence: elevation record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-PAM-03-003 — Constrain break-glass

Break-glass access **MUST** require a declared emergency, narrow scope, independent authorization where reachable, enhanced monitoring, immutable evidence, automatic expiry, and retrospective review within 24 hours.

- Applicability: emergencies
- Responsible role: Incident Commander
- Enforcement: emergency access workflow
- Required evidence: break-glass record and review
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-PAM-03-004 — Protect Owner ceremonies

Credentials or privileged access MUST NOT substitute for the Owner Authorization Ceremony or other constitutionally protected approval.

- Applicability: protected Owner actions
- Responsible role: Privileged Access Owner
- Enforcement: kernel authorization test
- Required evidence: ceremony evidence reference
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-PAM-03-005 — Issue workload-bound service identities

Each service identity MUST bind to an approved workload, environment, owner, capability need, permitted audience, credential method, and rotation/revocation policy.

- Applicability: service identities
- Responsible role: Service Owner
- Enforcement: workload identity admission
- Required evidence: service identity record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-PAM-03-006 — Eliminate embedded credentials

Credentials MUST NOT be stored in source, images, logs, tickets, prompts, generated artifacts, or unapproved configuration; discovery MUST trigger containment and rotation.

- Applicability: all artifacts
- Responsible role: Credential Custodian
- Enforcement: secret scanning and admission gates
- Required evidence: scan results and rotation record
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-PAM-03-007 — Rotate on defined triggers

Credentials MUST rotate on scheduled lifetime, exposure, custody change, algorithm or issuer weakness, workload change, environment migration, and incident direction.

- Applicability: all credentials
- Responsible role: Credential Custodian
- Enforcement: lifecycle controller
- Required evidence: rotation and revocation receipts
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-PAM-03-008 — Investigate privileged anomalies

Unexpected privilege use, failed elevation, geographic or workload mismatch, bulk access, disabled telemetry, or policy bypass attempt MUST create an incident-relevant event and risk-based response.

- Applicability: privileged activity
- Responsible role: Security Operations
- Enforcement: behavior detection
- Required evidence: security event and disposition
- Severity: Critical
- Exception authority: None
- Protection objective: Both

7. Required operating practices

Control Owners MUST maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 27, 38-40, 48
- Book II: Chapters 3-5, 23, 28, 33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-01-03, CMP-25-26
- Book X: Chapters 3-4, 8-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 4 — Cryptography, Secrets, Keys, and Certificates

1. Document control

- Identifier: HAL-BVI-04
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern approved cryptographic purposes, key and secret custody, certificate lifecycle, rotation, revocation, recovery, and cryptographic agility.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 23, 27, 39-40, 43
- Book II: Chapters 23, 28, 31, 33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-02, CMP-17, CMP-20-25
- Book X: Chapters 4, 7-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Cryptography Authority, Key Custodian, Certificate Operator, Service Owner, Security Operations, Independent Assessor.

6. Normative controls

VI-CRY-04-001 — Use approved cryptographic profiles

Cryptography **MUST** use approved algorithms, modes, key sizes, protocols, libraries, and purposes recorded in the cryptographic profile; custom cryptography is prohibited.

- Applicability: all cryptographic use
- Responsible role: Cryptography Authority
- Enforcement: build and configuration policy
- Required evidence: cryptographic inventory
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-CRY-04-002 — Separate keys by purpose and domain

Keys **MUST** be separated by environment, Trust Domain, principal or workload, purpose, data classification, and cryptographic operation; reuse across incompatible contexts is prohibited.

- Applicability: all keys
- Responsible role: Key Custodian
- Enforcement: key-policy enforcement
- Required evidence: key metadata
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-CRY-04-003 — Keep secrets out of ambient authority

Secrets **MUST** be referenced through governed secret services, scoped to the least audience and capability, short-lived where practical, auditable, and incapable of independently granting Authority.

- Applicability: all secrets
- Responsible role: Key Custodian
- Enforcement: secret broker and authority tests
- Required evidence: secret access evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-CRY-04-004 — Protect key custody

High-impact keys MUST use hardware-backed or equivalently isolated custody, dual control for protected operations, non-exportability where feasible, and independently tested recovery.

- Applicability: critical keys
- Responsible role: Key Custodian
- Enforcement: custody controls and ceremony review
- Required evidence: key ceremony record
- Severity: Critical
- Exception authority: Cryptography Authority
- Protection objective: Protect HAL

VI-CRY-04-005 — Verify certificates completely

Certificate validation MUST verify chain, identity, purpose, constraints, time, revocation, algorithm policy, and expected Trust Domain; possession alone MUST NOT imply authorization.

- Applicability: all certificate use
- Responsible role: Certificate Operator
- Enforcement: validation policy tests
- Required evidence: validation event
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-CRY-04-006 — Rotate and revoke safely

Rotation and revocation MUST define overlap, propagation, caches, in-flight work, offline nodes, failure behavior, receipts, and completion checks without weakening authority enforcement.

- Applicability: key and certificate changes
- Responsible role: Certificate Operator
- Enforcement: lifecycle orchestration
- Required evidence: rotation manifest
- Severity: High
- Exception authority: Cryptography Authority
- Protection objective: Both

VI-CRY-04-007 — Plan cryptographic agility

Every cryptographic dependency MUST identify replacement triggers, compatible migration path, inventory reachability, testing, rollback or forward recovery, and retained evidence.

- Applicability: all cryptographic systems
- Responsible role: Cryptography Authority
- Enforcement: annual agility review
- Required evidence: agility plan
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-CRY-04-008 — Respond to cryptographic compromise

Suspected key or issuer compromise **MUST** trigger containment, revocation, dependency impact analysis, reissuance, evidence preservation, and Book VIII-scoped reverification before restored trust.

- Applicability: compromise
- Responsible role: Security Operations
- Enforcement: incident playbook
- Required evidence: compromise recovery package
- Severity: Critical
- Exception authority: None
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 23, 27, 39-40, 43
- Book II: Chapters 23, 28, 31, 33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-02, CMP-17, CMP-20-25
- Book X: Chapters 4, 7-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 5 — Platform, Network, Workload, Build, and Supply-Chain Security

1. Document control

- Identifier: HAL-BVI-05
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Protect hosts, networks, workloads, execution boundaries, builds, artifacts, dependencies, and providers under compromised-component assumptions.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 17-25, 36-44, 47
- Book II: Chapters 2, 23, 28-33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-13-14, CMP-20, CMP-22-26
- Book X: Chapters 6-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Platform Security Owner, Network Security Owner, Build Custodian, Dependency Owner, Workload Owner, Security Assessor.

6. Normative controls

VI-PLT-05-001 — Harden from declared baselines

Hosts, runtimes, containers, orchestrators, and managed services **MUST** conform to versioned hardening baselines with deviations recorded, time-bounded, monitored, and tested.

- Applicability: all platforms
- Responsible role: Platform Security Owner
- Enforcement: configuration assessment
- Required evidence: baseline conformance evidence
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-PLT-05-002 — Segment by trust and authority

Network and workload paths **MUST** be allow-listed by authenticated identity, declared need, Trust Domain, data class, and permitted operation; network location **MUST NOT** establish trust.

- Applicability: all communications
- Responsible role: Network Security Owner
- Enforcement: policy-as-code and flow tests
- Required evidence: segmentation evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PLT-05-003 — Isolate workloads

Workloads **MUST** have separate identities, least resources, restricted host access, read-only roots where practical, controlled egress, bounded persistence, and containment against neighboring compromise.

- Applicability: all workloads
- Responsible role: Workload Owner
- Enforcement: admission and runtime policy
- Required evidence: workload attestation
- Severity: High
- Exception authority: Platform Security Owner
- Protection objective: Protect HAL

VI-PLT-05-004 — Build reproducibly

Release artifacts **MUST** be produced by isolated, pinned, reviewable builds with protected inputs, deterministic steps where feasible, independent verification, and no developer workstation as release authority.

- Applicability: release builds
- Responsible role: Build Custodian
- Enforcement: reproducible build gate
- Required evidence: build manifest and comparison
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-PLT-05-005 — Sign and verify provenance

Artifacts, dependencies, policies, configurations, and critical data packages **MUST** carry verifiable provenance and integrity; failed or unknown provenance **MUST** block protected use.

- Applicability: admitted artifacts
- Responsible role: Build Custodian
- Enforcement: admission verification
- Required evidence: provenance record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PLT-05-006 — Maintain dependency inventories

Every deployable unit **MUST** have a current transitive inventory, ownership, source, version, license disposition, integrity, support status, known risk, and replacement path.

- Applicability: all dependencies
- Responsible role: Dependency Owner
- Enforcement: SBOM and policy gate
- Required evidence: SBOM and disposition
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-PLT-05-007 — Assume component compromise

Architecture and operations **MUST** constrain a compromised node, provider, dependency, model, adapter, or service from acquiring authority, mutating foreign authoritative state, suppressing audit, or escaping its domain.

- Applicability: all components
- Responsible role: Security Assessor
- Enforcement: adversarial containment tests
- Required evidence: compromise containment report
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PLT-05-008 — Control external build services

External builders, registries, repositories, and vendors **MUST** be separate Trust Domains with explicit permitted exchanges, evidence, revocation paths, and no implicit constitutional trust.

- Applicability: external supply chain
- Responsible role: Build Custodian
- Enforcement: third-party and exchange review
- Required evidence: external service assessment
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 17-25, 36-44, 47
- Book II: Chapters 2, 23, 28-33
- Book III: Chapters 2, 5, 7
- Book IV: CMP-13-14, CMP-20, CMP-22-26
- Book X: Chapters 6-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 6 — Vulnerability, Exposure, and Patch Management

1. Document control

- Identifier: HAL-BVI-06
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Discover, validate, prioritize, remediate, disclose, and verify vulnerabilities and exposures without treating severity scores as sufficient risk judgment.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 26, 38, 42, 44
- Book II: Chapters 2, 28, 31-33
- Book III: Chapters 5, 7-9
- Book IV: CMP-24-26
- Book X: Chapters 7-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Vulnerability Program Owner, Asset Owner, Security Operations, Patch Authority, Risk Steward, Independent Assessor.

6. Normative controls

VI-VUL-06-001 — Maintain exposure-aware inventory

The vulnerability program MUST continuously map assets, versions, dependencies, internet and cross-domain exposure, identities, privileges, data classes, and authoritative responsibilities.

- Applicability: all assets
- Responsible role: Vulnerability Program Owner
- Enforcement: inventory reconciliation
- Required evidence: asset exposure inventory
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-VUL-06-002 — Accept findings from multiple channels

Automated scans, advisories, dependency intelligence, researcher reports, penetration tests, incidents, anomaly evidence, and internal review MUST enter one tracked disposition process.

- Applicability: all findings
- Responsible role: Vulnerability Program Owner
- Enforcement: intake workflow
- Required evidence: finding record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-VUL-06-003 — Prioritize by HAL consequence

Remediation priority MUST consider exploitability, exposure, privilege, authority path, data sensitivity, trust boundary, component ownership, containment, detectability, recovery, and credible harm—not severity score alone.

- Applicability: all findings
- Responsible role: Risk Steward
- Enforcement: risk scoring review
- Required evidence: prioritization rationale
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-VUL-06-004 — Meet risk-based remediation targets

Critical exploitable findings affecting authority, constitutional controls, protected state, external trust, or sensitive data **MUST** receive immediate containment and an approved remediation deadline.

- Applicability: critical findings
- Responsible role: Asset Owner
- Enforcement: SLA and containment gate
- Required evidence: containment and remediation evidence
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-VUL-06-005 — Test patches before adoption

Patches **MUST** undergo impact analysis, provenance validation, representative testing, rollback or forward-recovery preparation, and post-update verification proportional to urgency and consequence.

- Applicability: all patches
- Responsible role: Patch Authority
- Enforcement: change admission gate
- Required evidence: patch qualification record
- Severity: High
- Exception authority: Patch Authority
- Protection objective: Both

VI-VUL-06-006 — Do not remove critical checks for urgency

Emergency remediation **MAY** compress ordinary timing but **MUST NOT** bypass identity, Authority, constitutional invariants, provenance, evidence, or recovery controls.

- Applicability: emergency patches
- Responsible role: Patch Authority
- Enforcement: emergency change policy
- Required evidence: emergency patch record
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-VUL-06-007 — Verify closure

A finding closes only when the fix or compensating control is deployed to every in-scope asset, independently verified, monitored, and linked to residual risk; ticket closure alone is insufficient.

- Applicability: all remediations
- Responsible role: Independent Assessor
- Enforcement: retest and inventory reconciliation
- Required evidence: closure verification
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Protect HAL

VI-VUL-06-008 — Coordinate disclosure safely

Disclosure MUST protect affected people, preserve evidence, respect authorized reporting channels and Treaties, avoid enabling preventable harm, and never conceal material risk from accountable decision-makers.

- Applicability: disclosures
- Responsible role: Security and Trust Executive
- Enforcement: disclosure review
- Required evidence: disclosure decision record
- Severity: High
- Exception authority: Owner only for genuine Owner matters
- Protection objective: Both

7. Required operating practices

Control Owners MUST maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 26, 38, 42, 44
- Book II: Chapters 2, 28, 31-33
- Book III: Chapters 5, 7-9
- Book IV: CMP-24-26
- Book X: Chapters 7-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 7 — Privacy Governance, Classification, Purpose, and Data Lifecycle

1. Document control

- Identifier: HAL-BVI-07
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Operationalize dignity, classification, authority, collection and purpose limitation, minimization, retention, deletion, export, and lifecycle evidence.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Articles IX-X; Decisions 10, 30, 39-40, 45, 48, 55
- Book II: Chapters 12, 14, 18, 24, 27, 29
- Book III: Chapters 5-6, 8
- Book IV: CMP-08-10, CMP-18-19, CMP-24, CMP-27
- Book X: Chapters 7-8, 10
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Privacy Steward, Data Owner, Purpose Owner, Retention Owner, Privacy Engineer, Independent Assessor.

6. Normative controls

VI-PRV-07-001 — Classify before processing

Data **MUST** be classified before collection, inference, storage, use, disclosure, replication, or deletion; unknown classification **MUST** receive the most protective plausible handling.

- Applicability: all data
- Responsible role: Data Owner
- Enforcement: schema and admission validation
- Required evidence: classification record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PRV-07-002 — Prove purpose and authority

Every personal or sensitive-data operation **MUST** bind an authorized purpose, applicable Authority or consent basis, permitted processing, recipients, retention, and evidence.

- Applicability: personal and sensitive data
- Responsible role: Purpose Owner
- Enforcement: purpose-policy enforcement
- Required evidence: purpose and authority decision
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-PRV-07-003 — Collect the minimum

Collection **MUST** be limited to fields, precision, frequency, population, duration, and sources demonstrably necessary for the authorized purpose; convenience and possible future use are insufficient.

- Applicability: all collection
- Responsible role: Privacy Steward
- Enforcement: collection review and field gate
- Required evidence: minimization assessment
- Severity: Critical
- Exception authority: Privacy Steward
- Protection objective: Both

VI-PRV-07-004 — Prevent incompatible reuse

Data **MUST NOT** be reused, combined, enriched, modeled, or disclosed for a materially different purpose without a new valid authority and privacy assessment.

- Applicability: secondary use
- Responsible role: Purpose Owner
- Enforcement: purpose binding checks
- Required evidence: reuse decision record
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-PRV-07-005 — Set enforceable retention

Every data class **MUST** have an accountable retention rule, trigger, duration, legal or constitutional holds, archive behavior, backup treatment, and verifiable disposal path.

- Applicability: stored data
- Responsible role: Retention Owner
- Enforcement: retention controller
- Required evidence: retention schedule
- Severity: High
- Exception authority: Privacy Steward
- Protection objective: Both

VI-PRV-07-006 — Honor deletion across derived stores

Authorized deletion **MUST** address authoritative records, replicas, caches, indexes, embeddings, models where technically applicable, exports, and backups, while preserving required constitutional and incident accountability.

- Applicability: deletion requests
- Responsible role: Retention Owner
- Enforcement: deletion workflow and verification
- Required evidence: deletion certificate
- Severity: Critical
- Exception authority: Privacy Steward
- Protection objective: Both

VI-PRV-07-007 — Provide safe access and export

Access or export MUST verify requester identity and Authority, scope to the correct subject and purpose, preserve provenance and context, use secure delivery, and prevent disclosure of others' rights or secrets.

- Applicability: access and export
- Responsible role: Data Owner
- Enforcement: request validation
- Required evidence: access/export manifest
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PRV-07-008 — Minimize privacy evidence

Privacy compliance evidence MUST prove the decision without unnecessarily reproducing sensitive content; access to evidence MUST itself be classified, authorized, logged, and reviewed.

- Applicability: privacy evidence
- Responsible role: Evidence Custodian
- Enforcement: redaction and access controls
- Required evidence: minimized evidence manifest
- Severity: High
- Exception authority: Privacy Steward
- Protection objective: Both

7. Required operating practices

Control Owners MUST maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Articles IX-X; Decisions 10, 30, 39-40, 45, 48, 55
- Book II: Chapters 12, 14, 18, 24, 27, 29
- Book III: Chapters 5-6, 8
- Book IV: CMP-08-10, CMP-18-19, CMP-24, CMP-27
- Book X: Chapters 7-8, 10

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 8 — Sensitive Processing, Inference Risk, Human Dignity, and Privacy Incidents

1. Document control

- Identifier: HAL-BVI-08
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Control inference, sensitive processing, surveillance risk, human interaction, privacy testing, complaints, and privacy incident response.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Articles IX-XII; Decisions 26, 30, 33-35, 45, 48, 55-57
- Book II: Chapters 7, 12, 18, 27, 29, 34
- Book III: Chapters 4-6, 8
- Book IV: CMP-05-10, CMP-18-19, CMP-27-29
- Book X: Chapters 5, 7-8, 10
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Privacy Steward, Model Owner, Human Interaction Owner, Incident Commander, Data Owner, Independent Assessor.

6. Normative controls

VI-PIN-08-001 — Assess inference risk

Systems that infer identity, traits, relationships, emotion, health, beliefs, vulnerability, location, or intent MUST document necessity, uncertainty, affected people, misuse paths, validation, disclosure, retention, and denial or appeal.

- Applicability: sensitive inference
- Responsible role: Privacy Steward
- Enforcement: privacy impact assessment
- Required evidence: inference risk assessment
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-PIN-08-002 — Do not promote inference to fact

Inferred personal information MUST remain labeled with provenance, method, confidence, time, and contradiction; it MUST NOT be represented as observed fact or used beyond authorized purpose.

- Applicability: all inferences
- Responsible role: Model Owner
- Enforcement: data-model and output checks
- Required evidence: inference record
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-PIN-08-003 — Prohibit covert expansion

HAL MUST NOT increase observation, persistence, profiling, audience, or disclosure merely because a capability makes it possible; material expansion requires explicit authority and review.

- Applicability: sensitive processing changes
- Responsible role: Privacy Steward
- Enforcement: change impact gate
- Required evidence: privacy change decision
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-PIN-08-004 — Preserve human dignity and agency

Interfaces **MUST** make consequential collection, inference, disclosure, recording, and automated effects understandable and provide meaningful consent, correction, refusal, or escalation where constitutionally applicable.

- Applicability: human interactions
- Responsible role: Human Interaction Owner
- Enforcement: human-factors and privacy review
- Required evidence: interaction assessment
- Severity: Critical
- Exception authority: Owner only for genuine value conflict
- Protection objective: Constrain HAL

VI-PIN-08-005 — Test privacy failure paths

Privacy tests **MUST** cover wrong subject, overcollection, purpose drift, unauthorized audience, inference leakage, retention expiry, incomplete deletion, backup restore, cross-domain transfer, and evidence overexposure.

- Applicability: privacy-relevant systems
- Responsible role: Independent Assessor
- Enforcement: privacy test suite
- Required evidence: privacy verification report
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PIN-08-006 — Detect privacy incidents

Unauthorized, excessive, inaccurate, misleading, purpose-incompatible, retained-too-long, or improperly disclosed processing **MUST** enter the incident process even when no conventional security breach occurred.

- Applicability: all processing
- Responsible role: Privacy Steward
- Enforcement: privacy event detection
- Required evidence: privacy incident record
- Severity: High
- Exception authority: None
- Protection objective: Both

VI-PIN-08-007 — Contain without destroying accountability

Privacy incident containment **MUST** stop further harm, restrict access and exchange, preserve minimized evidence, identify affected data and people, and avoid deleting records needed for accountable investigation.

- Applicability: privacy incidents
- Responsible role: Incident Commander
- Enforcement: incident playbook
- Required evidence: containment record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-PIN-08-008 — Remediate affected lifecycle paths

Privacy remediation **MUST** address authoritative and derived stores, models, caches, backups, recipients, Treaties, purpose rules, access paths, and recurrence controls, with Book VIII reverification where claims were affected.

- Applicability: privacy incidents
- Responsible role: Data Owner
- Enforcement: remediation tracking
- Required evidence: privacy recovery package
- Severity: Critical
- Exception authority: Privacy Steward
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Articles IX-XII; Decisions 26, 30, 33-35, 45, 48, 55-57
- Book II: Chapters 7, 12, 18, 27, 29, 34
- Book III: Chapters 4-6, 8
- Book IV: CMP-05-10, CMP-18-19, CMP-27-29
- Book X: Chapters 5, 7-8, 10

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 9 — Trust Domains, Constitutional Firewall, and Cross-Domain Exchange

1. Document control

- Identifier: HAL-BVI-09
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern domain classification, authenticated boundaries, Constitutional Firewall decisions, exchange minimization, provenance, failure posture, and trust evidence.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 23, 26-27, 32, 35, 47, 54
- Book II: Chapters 16-17, 19-20, 26, 33
- Book III: Chapters 3, 5-6
- Book IV: CMP-17-21, CMP-24
- Book X: Chapters 7-8
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Trust Steward, Constitutional Firewall Owner, Domain Owner, Privacy Steward, Security Operations, Evidence Custodian.

6. Normative controls

VI-TRU-09-001 — Classify every Trust Domain

Every internal or external domain **MUST** have stable identity, owner, boundary, permitted purposes, data and capability scope, security and privacy assumptions, evidence, review cadence, and failure behavior.

- Applicability: all domains
- Responsible role: Trust Steward
- Enforcement: domain registry gate
- Required evidence: Trust Domain record
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-TRU-09-002 — Keep trust distinct

Trust Assessment **MAY** inform decisions but **MUST NOT** create identity, Permission, Authority, capability, Treaty scope, or truth; current authorization remains independently required.

- Applicability: all trust use
- Responsible role: Trust Steward
- Enforcement: negative authority tests
- Required evidence: trust decision evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-TRU-09-003 — Route cross-domain exchange through the Firewall

Every cross-domain ingress and egress **MUST** traverse the Constitutional Firewall with authenticated domain identity, active applicable Treaty where required, current Authority, purpose, classification, minimization, provenance, and integrity checks.

- Applicability: cross-domain exchange
- Responsible role: Constitutional Firewall Owner
- Enforcement: Book IX gateway enforcement
- Required evidence: Firewall decision and receipt
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-TRU-09-004 — Fail closed on missing boundary facts

Absent, stale, ambiguous, unverifiable, expired, revoked, suspended, drifted, or incompatible domain, Treaty, Authority, schema, provenance, or integrity evidence MUST deny or quarantine the exchange.

- Applicability: uncertain exchanges
- Responsible role: Constitutional Firewall Owner
- Enforcement: denial policy and adversarial tests
- Required evidence: denial or quarantine event
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-TRU-09-005 — Constrain returned data and effects

Firewall egress and ingress MUST enforce permitted direction, purpose, fields, classification, volume, frequency, recipients, actions, retention, and downstream propagation.

- Applicability: all exchanges
- Responsible role: Constitutional Firewall Owner
- Enforcement: content and policy enforcement
- Required evidence: exchange manifest
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-TRU-09-006 — Preserve cross-domain provenance

Accepted exchanges MUST retain source domain, identities, Treaty and Authority context, schema and contract versions, integrity, time confidence, transformations, and custody.

- Applicability: accepted exchanges
- Responsible role: Evidence Custodian
- Enforcement: Book IX envelope validation
- Required evidence: provenance chain
- Severity: High
- Exception authority: None
- Protection objective: Both

VI-TRU-09-007 — Monitor domain drift

Control, ownership, identity, endpoint, jurisdiction, purpose, behavior, assurance, incident, or threat changes MUST trigger Trust Assessment and Treaty applicability review.

- Applicability: active domains
- Responsible role: Domain Owner
- Enforcement: drift monitoring
- Required evidence: domain reassessment
- Severity: High
- Exception authority: Trust Steward
- Protection objective: Both

VI-TRU-09-008 — Exercise boundary failure

The program MUST test replay, substitution, downgrade, schema confusion, revoked Treaty, stale Authority, over-purpose, over-data, exfiltration, unavailable Firewall, and compromised counterparty scenarios.

- Applicability: external boundaries
- Responsible role: Security Operations
- Enforcement: adversarial gateway exercises
- Required evidence: boundary exercise report
- Severity: Critical
- Exception authority: None
- Protection objective: Both

7. Required operating practices

Control Owners MUST maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 23, 26-27, 32, 35, 47, 54
- Book II: Chapters 16-17, 19-20, 26, 33
- Book III: Chapters 3, 5-6
- Book IV: CMP-17-21, CMP-24
- Book X: Chapters 7-8

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 10 — Treaty Lifecycle and Third-Party Trust Governance

1. Document control

- Identifier: HAL-BVI-10
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern Treaty proposal, due diligence, Owner approval dependency, activation, monitoring, suspension, revocation, renewal, third-party risk, and exchange obligations.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 26, 47, 48, 54
- Book II: Chapters 17, 20, 26, 33, 35
- Book III: Chapters 5, 7-9
- Book IV: CMP-17, CMP-20-21
- Book X: Chapters 7-8
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Treaty Steward, Owner, Third-Party Risk Owner, Constitutional Firewall Owner, Privacy Steward, Incident Commander.

6. Normative controls

VI-TRT-10-001 — Perform Treaty due diligence

Before activation, the Treaty package **MUST** assess counterparty identity, ownership, purposes, data, capabilities, directions, controls, incidents, evidence, retention, deletion, jurisdiction, subcontractors, suspension, revocation, and exit.

- Applicability: proposed Treaties
- Responsible role: Treaty Steward
- Enforcement: due diligence gate
- Required evidence: Treaty assessment package
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-TRT-10-002 — Preserve Owner approval

No certification, security review, counterparty assurance, contract signature, credential, or technical connectivity **MAY** substitute for the constitutionally required Owner approval of a Treaty or new Treaty class.

- Applicability: Treaties
- Responsible role: Treaty Steward
- Enforcement: Owner-approval reference gate
- Required evidence: Owner authorization evidence
- Severity: Critical
- Exception authority: Owner
- Protection objective: Constrain HAL

VI-TRT-10-003 — Activate exact approved versions

Activation **MUST** bind the exact signed Treaty version, parties, domains, purposes, data classes, capabilities, directions, constraints, effective time, expiry, and Firewall policy; drift **MUST** block activation.

- Applicability: Treaty activation
- Responsible role: Constitutional Firewall Owner
- Enforcement: Book IX contract and policy gate
- Required evidence: activation record
- Severity: Critical
- Exception authority: None

- Protection objective: Both

VI-TRT-10-004 — Monitor Treaty obligations

Active Treaties MUST be monitored for expiry, permitted-use compliance, volume, recipients, incidents, assurance validity, retention, deletion, downstream sharing, and counterparty change.

- Applicability: active Treaties
- Responsible role: Treaty Steward
- Enforcement: continuous monitoring
- Required evidence: Treaty monitoring evidence
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-TRT-10-005 — Suspend on material uncertainty

Material incident, assurance loss, identity doubt, policy drift, contract mismatch, noncompliance, or revocation unreachability MUST suspend affected exchange pending review.

- Applicability: active Treaties
- Responsible role: Incident Commander
- Enforcement: automatic and manual suspension
- Required evidence: suspension record and receipts
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-TRT-10-006 — Revoke comprehensively

Revocation MUST stop new exchange, handle in-flight actions, invalidate cached permissions, quarantine affected data, notify authorized parties, preserve evidence, and evaluate dependent capabilities and certifications.

- Applicability: revoked Treaties
- Responsible role: Treaty Steward
- Enforcement: Book IX revocation workflow
- Required evidence: revocation manifest
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-TRT-10-007 — Control subcontractors and fourth parties

A third party **MUST NOT** extend access, data, capability, or processing to another domain unless the Treaty explicitly permits it and equivalent identity, security, privacy, evidence, and revocation controls are verified.

- Applicability: third-party chains
- Responsible role: Third-Party Risk Owner
- Enforcement: relationship and exchange review
- Required evidence: downstream party register
- Severity: Critical
- Exception authority: Owner if Treaty scope changes
- Protection objective: Both

VI-TRT-10-008 — Exit safely

Treaty expiry or termination **MUST** define return or deletion, retained evidence, credential and endpoint revocation, data quarantine, unresolved transactions, continuity, disputes, and post-exit verification.

- Applicability: Treaty exit
- Responsible role: Treaty Steward
- Enforcement: exit checklist and receipts
- Required evidence: exit evidence package
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 26, 47, 48, 54
- Book II: Chapters 17, 20, 26, 33, 35
- Book III: Chapters 5, 7-9
- Book IV: CMP-17, CMP-20-21
- Book X: Chapters 7-8

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 11 — Detection, Telemetry, and Security Operations

1. Document control

- Identifier: HAL-BVI-11
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Define privacy-minimized, incident-relevant telemetry; detection engineering; triage; alert quality; and protected evidence pipelines.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 26, 28, 40-42
- Book II: Chapters 28, 31-33
- Book III: Chapters 4-6, 8
- Book IV: CMP-18, CMP-24-26
- Book X: Chapters 7-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Detection Engineering Owner, Security Operations, Observability Owner, Privacy Steward, Control Owner, Evidence Custodian.

6. Normative controls

VI-DET-11-001 — Emit incident-relevant events

Identity, Authority, policy, privilege, secret, key, build, vulnerability, Firewall, Treaty, data, configuration, integrity, evidence, and recovery controls MUST emit structured success, denial, anomaly, and failure events.

- Applicability: critical controls
- Responsible role: Observability Owner
- Enforcement: Book IX event conformance
- Required evidence: event records
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-DET-11-002 — Use canonical telemetry context

Events MUST carry the applicable Book IX identity, correlation, causation, time, provenance, classification, integrity, contract/schema version, and optional Authority and Treaty context; missing critical context MUST reduce trust.

- Applicability: all security telemetry
- Responsible role: Observability Owner
- Enforcement: schema validation
- Required evidence: validated event stream
- Severity: High
- Exception authority: None
- Protection objective: Both

VI-DET-11-003 — Minimize and protect telemetry

Telemetry MUST exclude secrets and unnecessary sensitive content, apply field protection and access controls, use declared retention, and preserve sufficient evidence to reconstruct protected actions.

- Applicability: all telemetry
- Responsible role: Privacy Steward
- Enforcement: logging policy and scans
- Required evidence: telemetry data inventory
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-DET-11-004 — Detect authority violations separately

Detection content **MUST** identify attempted or actual excess Authority, stale delegation, bypassed Kernel or Firewall, foreign state mutation, and unauthorized Reality Boundary effects separately from compromise indicators.

- Applicability: authority paths
- Responsible role: Detection Engineering Owner
- Enforcement: authority-focused rules and tests
- Required evidence: authority incident alert
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-DET-11-005 — Validate detection quality

Critical detections **MUST** have test cases, required sources, expected latency, false-negative and false-positive review, owner, runbook, evidence links, and behavior for missing telemetry.

- Applicability: critical detections
- Responsible role: Detection Engineering Owner
- Enforcement: detection CI and exercises
- Required evidence: detection validation record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-DET-11-006 — Triage by consequence

Triage **MUST** assess constitutional impact, Authority, protected state, privacy, Trust Domain, Treaty, blast radius, persistence, evidence integrity, and recovery—not just technical severity.

- Applicability: all alerts
- Responsible role: Security Operations
- Enforcement: triage workflow
- Required evidence: triage record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-DET-11-007 — Protect evidence pipelines

Critical event collection **MUST** be tamper-evident, access-controlled, time-aware, resilient, independently monitored, and incapable of being silently disabled by the observed component.

- Applicability: critical telemetry
- Responsible role: Evidence Custodian
- Enforcement: pipeline integrity monitoring
- Required evidence: pipeline attestation
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-DET-11-008 — Measure coverage honestly

Coverage metrics **MUST** identify unmonitored assets, stale rules, missing fields, collection gaps, delayed events, untested scenarios, and blind spots; aggregate alert volume **MUST NOT** serve as assurance.

- Applicability: detection program
- Responsible role: Detection Engineering Owner
- Enforcement: coverage reconciliation
- Required evidence: detection coverage report
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 26, 28, 40-42
- Book II: Chapters 28, 31-33
- Book III: Chapters 4-6, 8
- Book IV: CMP-18, CMP-24-26
- Book X: Chapters 7-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 12 — Incident Response, Investigation, Evidence Preservation, and Notification

1. Document control

- Identifier: HAL-BVI-12
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern incident declaration, command, containment, investigation, chain of custody, communication, notification, and cross-domain coordination.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 22, 26, 28, 40, 42-43, 47
- Book II: Chapters 2, 18, 20, 28, 31-33
- Book III: Chapters 5-9
- Book IV: CMP-18-21, CMP-24-26
- Book X: Chapters 7-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Incident Commander, Security Operations, Privacy Steward, Trust Steward, Evidence Custodian, Service Owner.

6. Normative controls

VI-INC-12-001 — Declare incidents by consequence

Events **MUST** be declared incidents when credible impact involves constitutional invariants, Authority, identity, protected state, sensitive data, Trust Domains, Treaties, evidence, or continuity, even if technical certainty is incomplete.

- Applicability: suspected incidents
- Responsible role: Incident Commander
- Enforcement: incident criteria and escalation
- Required evidence: incident declaration
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-INC-12-002 — Establish one incident command

Each incident **MUST** have one accountable Incident Commander, scope, objectives, decision log, roles, communication channels, evidence custodian, status cadence, and transfer procedure.

- Applicability: all incidents
- Responsible role: Incident Commander
- Enforcement: incident management workflow
- Required evidence: incident record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-INC-12-003 — Contain proportionately

Containment **MUST** prioritize human safety, constitutional invariants, Owner access, Authority restriction, privacy, evidence, and blast-radius reduction; it **MUST** document intended and collateral effects.

- Applicability: all incidents
- Responsible role: Incident Commander
- Enforcement: containment approval and monitoring
- Required evidence: containment decision record
- Severity: Critical
- Exception authority: Incident Commander
- Protection objective: Both

VI-INC-12-004 — Preserve chain of custody

Investigation evidence **MUST** record identity, source, time and confidence, collection method, digest, classification, custody, access, transformations, analysis, and disposition; originals **MUST** be preserved where feasible.

- Applicability: all investigations
- Responsible role: Evidence Custodian
- Enforcement: evidence tooling and review
- Required evidence: chain-of-custody record
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-INC-12-005 — Separate facts from hypotheses

Investigations **MUST** distinguish observed facts, reported claims, analytical hypotheses, confidence, contradictions, unknowns, and decisions; later findings **MUST** supersede rather than rewrite history.

- Applicability: all investigations
- Responsible role: Security Operations
- Enforcement: case record schema
- Required evidence: investigation timeline
- Severity: High
- Exception authority: None
- Protection objective: Both

VI-INC-12-006 — Coordinate privacy and trust response

Incidents involving personal data or external domains **MUST** engage Privacy and Trust Stewards, enforce Treaty duties, minimize shared evidence, and coordinate suspension, notification, and remediation.

- Applicability: privacy/trust incidents
- Responsible role: Incident Commander
- Enforcement: stakeholder and Treaty gate
- Required evidence: coordination record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-INC-12-007 — Notify with verified scope

Notifications **MUST** be timely, authorized, accurate about known and unknown facts, purpose-limited, privacy-minimized, updateable, and linked to applicable Treaty, legal, operational, and governance duties.

- Applicability: notifiable incidents
- Responsible role: Incident Commander
- Enforcement: notification review
- Required evidence: notification record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-INC-12-008 — Prevent incident authority expansion

Emergency status **MUST NOT** grant undeclared strategic authority, alter constitutional invariants, create Treaties or capabilities, or permit unrestricted access; emergency powers **MUST** be explicit and expire.

- Applicability: emergencies
- Responsible role: Incident Commander
- Enforcement: emergency authority checks
- Required evidence: emergency authority record
- Severity: Critical
- Exception authority: Owner for constitutional matters
- Protection objective: Constrain HAL

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 22, 26, 28, 40, 42-43, 47
- Book II: Chapters 2, 18, 20, 28, 31-33
- Book III: Chapters 5-9
- Book IV: CMP-18-21, CMP-24-26
- Book X: Chapters 7-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 13 — Compromise Recovery, Offensive Assurance, Audit, and Security Certification Inputs

1. Document control

- Identifier: HAL-BVI-13
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern eradication, trusted recovery, penetration testing, red teaming, independent assessment, audit preparation, and evidence supplied to Book VIII.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 22, 26, 40, 42-44, 47, 58
- Book II: Chapters 2, 28, 30-33, 35
- Book III: Chapters 6-9
- Book IV: CMP-15-18, CMP-24-26
- Book X: Chapters 7-9
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Recovery Coordinator, Security Assessor, Red Team Lead, Audit Lead, Evidence Custodian, Certification Liaison.

6. Normative controls

VI-ASR-13-001 — Recover from trusted foundations

Compromise recovery MUST re-establish hardware or host trust, immutable identity, current Authority, protected configuration, verified artifacts, evidence integrity, and authoritative state before restoring capability.

- Applicability: compromise recovery
- Responsible role: Recovery Coordinator
- Enforcement: recovery admission gate
- Required evidence: trusted recovery record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-ASR-13-002 — Scope eradication to dependencies

Eradication MUST address persistence, credentials, keys, images, builds, dependencies, policies, data, peers, Treaties, caches, backups, and compromised evidence—not only the initially affected host.

- Applicability: confirmed compromise
- Responsible role: Recovery Coordinator
- Enforcement: dependency impact checklist
- Required evidence: eradication evidence
- Severity: Critical
- Exception authority: None
- Protection objective: Protect HAL

VI-ASR-13-003 — Require post-recovery verification

Restored systems MUST complete risk-based Book VIII verification, including containment, authority paths, privacy, trust boundaries, recovery invariants, and regression, before protected work resumes.

- Applicability: restored systems
- Responsible role: Certification Liaison
- Enforcement: verification admission status
- Required evidence: Book VIII result reference
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-ASR-13-004 — Authorize offensive testing

Penetration tests and red teams MUST have written scope, targets, time, allowed techniques, data handling, safety boundaries, stop authority, escalation, evidence, and cleanup before execution.

- Applicability: offensive tests
- Responsible role: Red Team Lead
- Enforcement: rules-of-engagement gate
- Required evidence: signed engagement plan
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-ASR-13-005 — Test both attacker and overreach paths

Adversarial work MUST test compromise of HAL and misuse or excess of HAL Authority, including stale delegation, trust confusion, Treaty bypass, evidence suppression, and unauthorized external effect.

- Applicability: high-risk systems
- Responsible role: Security Assessor
- Enforcement: scenario coverage review
- Required evidence: adversarial assessment
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-ASR-13-006 — Remediate findings with independent closure

Offensive and audit findings MUST enter the common risk process and close only after deployed remediation, independent retest, residual-risk decision, and affected-assurance review.

- Applicability: all findings
- Responsible role: Security Assessor
- Enforcement: finding workflow
- Required evidence: retest and closure record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-ASR-13-007 — Prepare auditable evidence

Audit packages **MUST** state scope, criteria, sources, sampling, limitations, control owners, evidence locations, access decisions, exceptions, findings, remediation, and unresolved risk without fabricating assurance.

- Applicability: audits
- Responsible role: Audit Lead
- Enforcement: audit readiness review
- Required evidence: audit evidence manifest
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-ASR-13-008 — Supply but do not issue certification

Book VI **MUST** supply security, privacy, trust, incident, recovery, and control-effectiveness evidence to Book VIII; Book VI roles **MUST NOT** issue or redefine certification unless separately authorized there.

- Applicability: certification inputs
- Responsible role: Certification Liaison
- Enforcement: Book VIII reconciliation gate
- Required evidence: assurance evidence package
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 22, 26, 40, 42-44, 47, 58
- Book II: Chapters 2, 28, 30-33, 35
- Book III: Chapters 6-9
- Book IV: CMP-15-18, CMP-24-26
- Book X: Chapters 7-9

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Chapter 14 — Metrics, Continuous Improvement, Reconciliation, and Program Conformance

1. Document control

- Identifier: HAL-BVI-14
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Maintain meaningful metrics, learning without evidence loss, Book VIII and IX alignment, program reporting, and final conformance.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Articles XI-XIV; Decisions 22, 26, 28, 40, 58
- Book II: Chapters 28, 31-35
- Book III: Chapters 4-9
- Book IV: CMP-15, CMP-18, CMP-24-29
- Book X: Chapters 7-10
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Security and Trust Executive, Metrics Owner, Control Owner, Book VIII Liaison, Book IX Liaison, Independent Assessor.

6. Normative controls

VI-CON-14-001 — Measure outcomes and control health

Metrics **MUST** cover prevention, detection, containment, recovery, authority denials, privacy outcomes, trust-boundary enforcement, evidence quality, exceptions, remediation, and recurrence.

- Applicability: program metrics
- Responsible role: Metrics Owner
- Enforcement: metric definition review
- Required evidence: metrics catalog and reports
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-CON-14-002 — Prevent vanity metrics

Alert count, patch count, scan count, training completion, coverage percentage, or audit completion **MUST NOT** alone demonstrate effective risk reduction or constitutional conformance.

- Applicability: all reporting
- Responsible role: Metrics Owner
- Enforcement: report review
- Required evidence: metric interpretation record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-CON-14-003 — Track leading and lagging signals

Each critical risk **MUST** have outcome, control-effectiveness, exposure, evidence-freshness, and failure signals with owners, thresholds, cadence, and response.

- Applicability: critical risks
- Responsible role: Control Owner
- Enforcement: risk-to-metric mapping
- Required evidence: risk monitoring record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-CON-14-004 — Learn without rewriting history

Improvements **MUST** preserve prior incidents, findings, decisions, exceptions, evidence, and dissent; updated understanding **MUST** be versioned and linked to outcomes.

- Applicability: all improvements
- Responsible role: Control Owner
- Enforcement: append-only records
- Required evidence: improvement decision
- Severity: High
- Exception authority: None
- Protection objective: Both

VI-CON-14-005 — Reconcile Book IX contracts

Security events, Authority context, Treaty exchange, Firewall decisions, errors, schemas, and protocol behaviors **MUST** map to final Book IX identifiers and **MUST NOT** invent alternate wire contracts.

- Applicability: interface controls
- Responsible role: Book IX Liaison
- Enforcement: contract reconciliation check
- Required evidence: Book IX mapping register
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-CON-14-006 — Reconcile Book VIII assurance

Control tests, incidents, penetration results, privacy assessments, Treaty evidence, recovery, and continuous signals **MUST** map into Book VIII claims, evidence, certification status, and recertification triggers.

- Applicability: assurance inputs
- Responsible role: Book VIII Liaison
- Enforcement: assurance reconciliation check
- Required evidence: Book VIII mapping register
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-CON-14-007 — Review the program periodically

At least annually and after material incidents or canon changes, an independent review **MUST** assess source fidelity, control effectiveness, gaps, burden, exceptions, evidence, roles, metrics, and needed revisions.

- Applicability: program
- Responsible role: Independent Assessor
- Enforcement: review calendar and gate
- Required evidence: program review report
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-CON-14-008 — Certify Book VI conformance honestly

Book VI conformance **MAY** be declared only when mandatory controls are mapped, applicable evidence is current, critical failures are resolved or operation is constrained, reconciliations are current, and no contradiction remains.

- Applicability: Book VI conformance
- Responsible role: Security and Trust Executive
- Enforcement: certification checklist
- Required evidence: Book VI certification report
- Severity: Critical
- Exception authority: None
- Protection objective: Both

7. Required operating practices

Control Owners **MUST** maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence **MUST** identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated **MUST** deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation **MUST** expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer **MUST** evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions **MUST** fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations **MUST** minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics **MUST** measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Articles XI-XIV; Decisions 22, 26, 28, 40, 58
- Book II: Chapters 28, 31-35
- Book III: Chapters 4-9
- Book IV: CMP-15, CMP-18, CMP-24-29
- Book X: Chapters 7-10

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a trusted credential, passing scan, active certificate, or urgent incident as permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.

Appendices

Appendix A — Control categories

GOV governance; IAM identity and access; PAM privileged access; CRY cryptography; PLT platform and supply chain; VUL vulnerability; PRV privacy lifecycle; PIN privacy/inference incidents; TRU trust domains and Firewall; TRT Treaties; DET detection; INC incidents; ASR assurance and recovery; CON conformance.

Appendix B — Canonical incident distinctions

- Security incident: threatens confidentiality, integrity, availability, provenance, identity, or control effectiveness.
- Authority incident: actual, attempted, or credible excess of valid Authority.
- Privacy incident: unauthorized, excessive, misleading, inaccurate, or purpose-incompatible processing.
- Trust incident: invalidates assumptions about a Trust Domain, Treaty, counterparty, or exchange path.

One event may have several classifications. Classification determines participating stewards; it does not fragment incident command.

Appendix C — Book VIII and IX boundaries

Book VIII owns verification and certification rules, decisions, states, suspension, revocation, and assurance cases. Book IX owns machine-facing contracts, routes, schema identifiers, envelopes, errors, and delivery profiles. Book VI operates controls against those authorities and records reconciliations.

Appendix D — Certification status

All 14 chapters and 112 controls are complete. Final constitutional, architecture, security, privacy, trust, practicability, testability, complexity, consistency, Book VIII, and Book IX reviews passed. No Owner Review item is required.